

CONCERTX — EVALUACIÓN 2 DESARROLLO PARA DISPOSITIVOS INTELIGENTES

SA.4 — Documento de seguridad

Matrícula: 2023371079

Este documento describe las medidas de seguridad de la comunicación entre pantallas, el tratamiento de datos personales conforme a la LFPDPPP, y el estado de los controles de seguridad de la aplicación Concertx (teléfono, reloj y Smart TV).

1. Validación de origen en la comunicación entre pantallas

1.1 Mecanismo utilizado

El teléfono y la Smart TV pueden sincronizarse mediante un canal `BroadcastChannel` del navegador, usado como respaldo cuando ambos clientes corren en el mismo dispositivo (por ejemplo, en pruebas locales). El mecanismo principal de sincronización sigue siendo un `WebSocket` contra el backend; el `BroadcastChannel` es una vía secundaria.

1.2 Problema detectado

Antes de esta revisión, el código ya validaba el campo `type` del mensaje recibido, pero nunca comprobaba `event.origin`. Aunque `BroadcastChannel` es same-origin por especificación (un script de otro dominio no puede suscribirse al mismo canal), depender solo de ese supuesto deja sin cubrir escenarios como que la TV se incruste en un `iframe` de otro origen, o que el canal se cree antes de que el documento resuelva su `origin` final.

1.3 Corrección aplicada

Se agregó una validación explícita de `event.origin` contra `window.location.origin` como defensa en profundidad, además de mantener la validación de tipo ya existente:

```
channel.onmessage = (event) => {  
  if (event.origin && event.origin !== window.location.origin) {  
    console.warn('mensaje descartado:  origen inesperado');  
    return;  
  }  
  if (!event.data || typeof event.data !== 'object') return;  
  if (!event.data.type) return;  
  handleMessage(event.data);  
};
```

Cualquier mensaje con un origen distinto se descarta y queda registrado con `console.warn` para poder auditarlo.

2. Datos personales tratados (LFPDPPP)

Dato	Clasificación	Base legal
Nombre, correo y contraseña (almacenada como <i>hash</i>)	Dato personal ordinario	Art. 8 LFPDPPP — consentimiento tácito: el usuario lo entrega voluntariamente al registrarse
Ritmo cardíaco (BPM) y oxígeno en sangre (SpO2 %)	Dato personal sensible (Art. 3 fracción VI — relacionado con la salud)	Art. 9 LFPDPPP — requiere consentimiento expreso ; el flujo de registro actual no presenta un aviso ni una casilla de consentimiento específico para este dato
Calorías estimadas, color de efecto, estado de vibración	Dato personal ordinario	Art. 8 LFPDPPP — consentimiento tácito, uso funcional de la app
Diseños y eventos creados por el usuario	Dato personal ordinario	Art. 8 LFPDPPP — consentimiento tácito

No se detectó captura de ubicación geográfica en ninguno de los tres clientes, por lo que no aplica una base legal para ese tipo de dato.

3. Aviso de privacidad

Responsable: _____, con domicilio en _____, es responsable del tratamiento de los datos personales recabados a través de la aplicación Concertx (teléfono, reloj Wear OS y pantalla de Smart TV), en cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP).

Datos recabados: datos de identificación y contacto (nombre, correo, contraseña protegida mediante *hash*); datos de salud (ritmo cardíaco y SpO2, capturados vía Bluetooth Low Energy); datos de uso (calorías estimadas, efectos configurados, diseños y eventos creados).

Finalidad: los datos de cuenta se usan para autenticar al usuario y asociarle sus diseños y eventos. Los datos de salud se usan únicamente para mostrarlos al propio usuario en tiempo real y para activar alertas cuando el ritmo cardíaco supera el umbral configurado (100 BPM); no se usan con fines de mercadotecnia ni se comparten con terceros.

Transferencias: los datos se almacenan en un proveedor de base de datos en la nube y la API se aloja en un servicio de hospedaje web, ambos como encargados del tratamiento bajo sus respectivos términos de servicio. No se realizan otras transferencias a terceros.

Derechos ARCO: el usuario puede ejercer en cualquier momento sus derechos de Acceso, Rectificación, Cancelación y Oposición, enviando una solicitud a _____ con: (a) nombre completo, (b) documento que acredite su identidad, (c) descripción del derecho que desea ejercer. Se responderá en un plazo máximo de 20 días hábiles, conforme al Art. 32 LFPDPPP.

Revocación del consentimiento: el usuario puede revocar el consentimiento otorgado para el tratamiento de sus datos de salud desconectando el reloj y solicitando la eliminación de su historial por el mismo medio de contacto.

4. Plan de retención de datos

Categoría	Retención	Mecanismo de eliminación
Historial de lecturas del reloj (ritmo, oxígeno, calorías, color, vibración)	12 meses	(Planeado, no implementado a nivel SA) tarea programada que elimine los registros con más de 12 meses de antigüedad
Cuentas de usuario inactivas	24 meses sin inicio de sesión	(Planeado) aviso previo por correo 30 días antes; la eliminación de la cuenta dispara un borrado en cascada ya definido a nivel de base de datos
Diseños y eventos creados	Mientras la cuenta exista	Se eliminan junto con la cuenta mediante el mismo borrado en cascada

5. Checklist de seguridad de la PWA

Control	Estado	Detalle
Content Security Policy (CSP)	Implementado	Meta tag con default-src, script-src, style-src, connect-src, img-src y media-src definidos
HTTPS en el backend	Implementado	La API se sirve completamente sobre HTTPS con cabecera Strict-Transport-Security
CSP apuntando al backend en HTTPS	Implementado	connect-src apunta al dominio HTTPS del backend en los tres clientes
WebSocket en HTTPS/WSS	Limitación conocida	El proveedor de hospedaje actual no soporta conexiones persistentes; el WebSocket sigue operando en red local sobre ws://, no wss://
Subresource Integrity (SRI)	Pendiente	Los recursos externos (como las fuentes web) se cargan sin atributo integrity
Validación de event.origin en mensajería entre contextos	Corregido	Ver Sección 1
Contraseñas con hash (no texto plano)	Implementado	Se usa bcrypt para el almacenamiento de contraseñas